

MixLabs Workspace

Post-Production Project Management & Client Review Platform

Developer Handover & Technical Report

A complete map of the stack, services, configuration, data model, security posture, running costs and maintenance requirements — prepared so an independent developer can review, run and extend the application.

Application URL	https://project.mixlabscreative.com
Marketing site	https://mixlabscreative.com (Framer)
Code repository	github.com/raviroshanmusic/mixlabs-studio (branch: main)
Document date	July 2026
Prepared for	Independent developer review

This document is a point-in-time snapshot. Secrets/keys are intentionally omitted — they live in the hosting provider's environment variables and the respective service dashboards.

1 Executive Summary

MixLabs Workspace is a private, invite-only SaaS for a film post-production studio. It lets the studio manage projects, share draft deliverables (score, sound, color, edit, VFX, animation), collect timecoded client feedback in a review room, track a production timeline, manage deliveries, receive editorial turnover files from clients, and keep pre-production reference documents — all with email notifications and role-based access.

It is a modern **Next.js (App Router)** application written in **TypeScript**, deployed on **Vercel**, backed by **Supabase** (PostgreSQL + authentication) with **Backblaze B2** for large media files and **Resend** for transactional email. The domain is registered at **Porkbun**; the public marketing site is built on **Framer**.

The codebase is small, strictly typed, and organised by feature. Security is enforced primarily through PostgreSQL Row-Level Security (RLS), with route-level authentication and a file-access guard as defense-in-depth.

2 Technology Stack

Layer	Technology	Notes
Framework	Next.js (App Router) + React 18	Server components + API route handlers
Language	TypeScript (strict mode)	tsc passes clean; no implicit any policy
Styling	Tailwind CSS 3.4	CSS variables drive light/dark theming
Animation	Framer Motion	Used on the landing page only
Icons	lucide-react	—
Database	Supabase (PostgreSQL)	Row-Level Security on every table
Auth	Supabase Auth (@supabase/ssr)	Cookie-based sessions, email confirm + reset
File storage	Backblaze B2 (S3-compatible)	via @aws-sdk/client-s3 + presigned URLs
Email	Resend	REST API for app emails; SMTP for auth emails
Hosting	Vercel	Auto-deploy from GitHub main branch
Marketing site	Framer	Separate from the app; same domain root
Domain / DNS	Porkbun	Registrar + authoritative DNS

3 Services, Websites & Accounts Used

Every third-party service the application depends on. Each has its own dashboard/login owned by the studio.

Service	Purpose	Plan / Tier	Key identifiers
GitHub	Source code repository	Free	raviroshanmusic/mixlabs-studio
Vercel	App hosting + CI/CD	Hobby (free)	project: mixlabs-studio
Supabase	Database + authentication	Free tier	region: ap-northeast-2 (Seoul)
Backblaze B2	Media / file storage	Pay-as-you-go	bucket: mixlabsmedia (us-east-005)
Resend	Transactional email	Free (3k/mo)	domain: updates.mixlabscreative.com
Porkbun	Domain registrar + DNS	Paid (~\$11/yr)	mixlabscreative.com

Service	Purpose	Plan / Tier	Key identifiers
Framer	Marketing website	Framer plan	mixlabscreative.com (root + www)

Decommissioned / to clean up: The domain was previously on **Wix** (registrar + site) — now fully migrated away; the Wix subscription can be cancelled. A **Cloudflare** account/zone was created during migration but is **not used** in the final setup and can be deleted.

4 Environment Variables

The application reads exactly seven environment variables. They must be set both locally (`.env.local`, git-ignored) and in the Vercel project settings (Production). A template lives at `.env.local.example`.

Variable	Service	Secret?	Where to get it
NEXT_PUBLIC_SUPABASE_URL	Supabase	Public	Supabase > Project Settings > API
NEXT_PUBLIC_SUPABASE_ANON_KEY	Supabase	Public*	Supabase > Project Settings > API
B2_KEY_ID	Backblaze	Secret	B2 > Application Keys (non-master)
B2_APPLICATION_KEY	Backblaze	Secret	B2 > Application Keys (shown once)
B2_BUCKET_NAME	Backblaze	Low	B2 bucket name (mixlabsmedia)
B2_ENDPOINT	Backblaze	Low	e.g. https://s3.us-east-005.backblazeb2.com
RESEND_API_KEY	Resend	Secret	Resend > API Keys (Sending access)

* The Supabase anon key is safe to expose publicly because Row-Level Security protects the data; it is only an identity token, not an authorization bypass.

5 Database (Supabase / PostgreSQL)

A single Supabase project hosts all application data in PostgreSQL. Every table has Row-Level Security enabled with owner-or-member policies. The core tables:

Table	Holds	Access rule (RLS)
profiles	User profile, avatar, notify prefs	Read: all authed; write: own row
projects	Projects (name, client, status, owner)	Owner or member
project_members	Team membership + role	Owner adds; members can read team
project_invites	Pending invites	Owner only
project_versions	Drafts / deliverable versions	Owner or member
review_comments	Timecoded review notes	Owner or member
project_milestones	Timeline milestones	Owner or member
project_deliveries	Final deliveries	Owner or member
project_documents	Pre-Pro reference docs	Owner or member
project_exchange	Handoff / turnover files	Owner or member

Migrations. Schema changes are plain SQL files in the repo root, run manually in the Supabase SQL editor. Run these once each (idempotent / safe to re-run) when provisioning a fresh database, roughly in this order:

- `supabase-schema.sql` — base tables + new-user trigger (notes/setup)
- `supabase-migration-member.sql` — membership helpers
- `supabase-migration-staff.sql` — staff allow-list function
- `supabase-migration-isolation.sql` — **RLS hardening** (removes permissive policies)
- `supabase-migration-timeline.sql` — milestone columns
- `supabase-migration-deliveries.sql` — deliveries table
- `supabase-migration-prepro.sql` — pre-pro docs + brief
- `supabase-migration-team-visibility.sql` — members see full team
- `supabase-migration-exchange.sql` — handoff files table
- `supabase-security-audit.sql` — **read-only** RLS verification (run anytime)

Note: `staff / project-creation` is limited to an allow-list of emails defined in `src/lib/staff.ts` AND mirrored in `supabase-migration-staff.sql` — these two must stay in sync.

6 File Storage (Backblaze B2)

Large media (draft videos, avatars, documents, turnover files) is stored in a **private** Backblaze B2 bucket via the S3-compatible API. Files never pass through Vercel — the browser uploads directly to B2 using short-lived presigned URLs, and downloads/streams go through a guarded proxy route.

- Uploads: browser requests a presigned PUT from `/api/upload/presign`, which validates the file type and confirms the caller can write to that project before signing.
- Downloads/streaming: `/api/media` checks authorization then streams the file; non-inline types are forced to download with an anti-sniffing header.
- Key namespaces: `projects/{projectId}/...` and `avatars/{userId}/...`
- Authorization: `src/lib/access.ts` (`canAccessKey`) — B2 is outside RLS, so this guard re-derives the owning id from the key and confirms membership; default-deny.

Because B2 keys live outside the database, use a **non-master, bucket-scoped Application Key**. The bucket must remain **Private**.

7 Email (Resend)

Two email streams, both sent from the verified sub-domain `updates.mixlabscreative.com`:

- **Auth emails** (email confirmation, password reset) — sent by **Supabase** via custom SMTP pointed at Resend (host `smtp.resend.com:465`, user `resend`, sender `noreply@updates.mixlabscreative.com`).
- **Notification emails** (new draft uploaded, new review comment) — sent by the app directly through the Resend REST API in `src/lib/email.ts`, honouring each user's notification preferences.

Auth email templates in Supabase were customised to use a `token_hash` link pointing at `/auth/callback`, which the app verifies server-side. Do not revert these to the default template or reset/confirm links will break.

8 Authentication & Authorization

- Sessions are cookie-based via @supabase/ssr; each server component / route calls getUser() and redirects if unauthenticated.
- **Email confirmation is ON** — new signups must confirm before logging in.
- **Password reset**: login > Forgot password > email > /auth/callback (verifies token) > /reset-password.
- **Project creation** is restricted to a staff email allow-list.
- **Member invites** are restricted to the project owner (route + RLS).
- Roles: owner, admin, editor, viewer — drive edit/manage permissions in the UI; RLS enforces data access.

Supabase Auth > URL Configuration must keep Site URL = `https://project.mixlabscreative.com` and allow redirect `.../**`.

9 Domain & DNS (Porkbun)

The domain **mixlabscreative.com** is registered at Porkbun, which is also the authoritative DNS host (Porkbun nameservers). Three sub-uses:

Host	Type	Points to	Serves
@ (root)	A	31.43.160.6 / 31.43.161.6	Framer marketing site
www	CNAME	sites.framer.app	Framer marketing site
project	CNAME	...vercel-dns-017.com	The app (Vercel)
resend._domainkey.updates	TXT	DKIM key	Email auth (Resend)
send.updates	MX	feedback-smtp.ap-northeast-1.amazonses.com	Email (Resend, prio 10)
send.updates	TXT	v=spf1 include:amazonses.com ~all	Email SPF
_dmarc	TXT	v=DMARC1; p=none;	Email DMARC

10 Feature Inventory

- **Dashboard** — grid of all projects with search/filter; entry point.
- **Project workspace** with tabs: Drafts, Pre-Pro, Handoff, Timeline, Delivery, Team, Settings.
- **Drafts** — upload versioned deliverables per department; click a draft to open it in the review room.
- **Pre-Pro** — project brief (logline/synopsis/specs) + categorised reference document library.
- **Handoff** — client drop-zone for editorial turnover files (AAF, XML/FCPXML, EDL, OTIO, MOV, stems).
- **Timeline** — draggable Gantt of milestones with progress, overdue flags, version links.
- **Delivery** — final deliverables tracking.
- **Team** — invite members by email, roles; emails hidden, names shown as 'First L'.
- **Review Room** — video player with timecoded comments, version switching, status, notes export.
- **Notifications** — email on new draft / new comment (per-user preferences).
- **Profile** — avatar upload, password change, notification prefs, light/dark theme.
- **Responsive** — desktop sidebar + mobile bottom-nav; light & dark modes.

11 Security Posture

Reviewed across the main attack surfaces. Summary of controls in place:

- **Row-Level Security** on every table (owner-or-member) — the primary boundary, enforced by PostgreSQL even against direct API calls.
- **Route auth** — every data endpoint verifies the session; only login/signup/callback are public.
- **File access guard** (canAccessKey) with default-deny; presign verifies write access before signing.
- **No service_role key** in the codebase — only the public anon key.
- **Staff-gated** project creation; **owner-gated** member invites (also closes email-enumeration).
- **No SQL injection** (parameterised queries) and **no XSS** (React escaping; the one inline script is static; email templates escape user input).
- **Upload safety** — dangerous extensions blocked; media forces download + nosniff for non-inline types.
- **Mass-assignment** prevented via field whitelists on PATCH routes.
- **CSRF** mitigated by SameSite=Lax auth cookies.

Reviewer action items: (1) run `supabase-security-audit.sql` and confirm RLS is enabled everywhere with no permissive INSERT/UPDATE/DELETE policies; (2) confirm the B2 bucket is Private; (3) consider adding per-IP rate-limiting (e.g. Upstash) — auth endpoints are already throttled by Supabase.

12 Repository Structure

```
src/app/ Next.js App Router
page.tsx layout.tsx icon.svg globals.css landing, root, favicon, styles
(auth)/login reset-password auth screens
(app)/dashboard member app screens
(app)/project/[id] project workspace + tabs
ProjectClient / FilesTab / PreProTab /
ExchangeTab / Timeline / Delivery
(app)/review/[id] ReviewClient review room
auth/callback/route.ts email-link verification
api/.../route.ts REST endpoints (auth-gated)
src/components/ui/ Sidebar, B2Upload, Logo, etc.
src/lib/ supabase, b2, access, email, staff
src/hooks/useTheme.ts light/dark theme
*.sql (repo root) database migrations + audit
```

Deployment: push to the main branch on GitHub → Vercel builds and deploys automatically. No manual deploy step. Environment-variable changes require a redeploy to take effect.

13 Running Costs

Service	Current cost	When it changes
Vercel	\$0 (Hobby)	Pro ~\$20/mo when fully commercial / higher limits
Supabase	\$0 (Free)	Pro \$25/mo for no-pause + daily backups (recommended pre-scale)
Backblaze B2	~\$6 / TB / month storage	Scales with stored media; egress ~\$10/TB
Resend	\$0 (3,000 emails/mo)	Paid tier if you exceed the free volume
Porkbun domain	~\$11 / year	Annual renewal (keep auto-renew on)
Framer	Existing Framer plan	Marketing site — billed separately

Effective fixed cost today is essentially the ~\$11/yr domain plus minimal B2 storage. Budget for Supabase Pro (\$25/mo) once real client data must never pause and needs proper backups.

14 What Must Be Maintained (Keep-It-Running Checklist)

Recurring / watch:

- **Supabase free project pauses after ~7 days of inactivity** — resume it in the dashboard, or upgrade to Pro to avoid pauses. A live app with traffic won't pause.
- **Domain renewal** at Porkbun (~\$11/yr) — keep auto-renew enabled so it never expires.
- **B2 storage growth** — monitor usage/cost as footage accumulates; set caps/alerts in Backblaze.
- **Resend volume** — free tier is 3,000 emails/month; upgrade if notification volume grows.
- **Backups** — free Supabase has limited backups; Pro adds point-in-time recovery. Enable before holding critical client data.

One-time / on change:

- Run any un-applied SQL migration in the Supabase SQL editor (see §5).
- Keep the staff allow-list in sync between `src/lib/staff.ts` and `supabase-migration-staff.sql`.
- After changing env vars in Vercel, trigger a redeploy.
- Rotate secrets periodically (B2 application key, any API keys).
- Cancel the old **Wix** subscription; optionally delete the unused **Cloudflare** zone.

15 Known Items & Recommendations for the Reviewer

Item	Priority	Detail
Lint tooling	Low	Next 16 removed `next lint`; eslint-config-next is 14.2.5. Set up an ESLint 9 flat config (<code>eslint.config.mjs</code>) with the Next plugin.
Rate limiting	Low	No custom per-IP limiting; auth endpoints throttled by Supabase. Add Upstash Redis limiting on sensitive routes if abuse appears.
RLS verification	High	Run <code>supabase-security-audit.sql</code> on the live DB and confirm no permissive policies remain.
B2 bucket privacy	High	Confirm the bucket is Private (files only via signed URLs).
Secret rotation	Medium	Rotate the B2 application key and any tokens that were shared during setup.
Type escapes	Info	Only two `as any` casts in the codebase; otherwise strict TypeScript.
Supabase config in code	Info	URL + anon key read from env with a public fallback baked in (safe; RLS-protected).

Prepared as a technical handover for independent developer review. All credentials/keys are held in the respective service dashboards and the Vercel environment — not in this document or the source repository.